開発意図と静的・動的解析を照合する Androidアプリ通信の確認支援システム

静的候補と指定操作下の通信による開発者向け自己確認

著者名・所属・学籍番号：提出時に記入

2026年11月6日改訂
目的・方法・結果・考察を整理した卒業論文草稿

概要

開発者が意図した通信とアプリの振る舞いを確認するため，構造化した開発意図，Android APK，操作シナリオを入力する確認支援システムを実装した。静的な宣言・候補と対象UIDの動的通信を照合し，不一致候補，観測範囲の整合，要確認，判定不能を根拠への参照付きで示す。同一AVD上の自作3 APK・計9試行で，許可入力先への要求3件を整合，同一ホストの許可外ポートへの要求3件を不一致候補とした。75秒後に要求する素材を入力後30秒で観測した3試行は，対象未観測の判定不能となった。これらはソース仕様と規則から期待出力を定めた動作確認である。自作の固定先素材では文字列抽出で宛先候補を得られず，動的に要求を記録したが，通信判定は動的のみと併用で一致した。原本から照合出力を再現し，設計した規則が参照条件で期待どおり動作することを確認した。帰属不明の保持は補助群の事後解析で確認した。評価は同じ開発側の素材に依存し，送信内容やアプリ全体の安全性の保証を含めない。

キーワード：Android，開発意図，静的解析，動的通信解析，意図照合，確認支援

利用にあたって　本稿は目的・方法・結果・考察・結論を備えた卒業論文草稿であり，提出確定版ではない。既存実験の事後評価とAI支援による点検を明記し，独立した正解や方法上の新規性を架空に補わない。著者情報，大学の形式，指導教員による研究範囲の確認を経て提出版とする。

目次

1 研究背景と問題設定 4
1.1 開発意図とアプリの振る舞いを確認する必要性 4
1.2 静的解析と動的観測の相補性 4
1.3 研究目的と主張の範囲 4
1.4 利用者と本研究の構成 4

2 関連研究と本研究の位置付け 5
2.1 静的・動的解析と実行支援 5
2.2 プライバシーポリシーと挙動の整合性検査 5
2.3 差分観測と本研究の位置付け 6

3 理論モデル 6
3.1 入力と証拠の形式化 6
3.2 開発意図の明示性 6
3.3 部分情報に基づく判定 7
3.4 独立した観測軸 7
3.5 ホスト名照合と未知値 7
3.6 アプリ帰属 8
3.7 操作との時間的対応 8
3.8 未観測の条件 8
3.9 時刻の不確実性と実装範囲 8
3.10 静的候補と実測の対応・差分モデル 8
3.11 差分を説明する情報の分離 9
3.12 研究用要求の補助点検 9

4 システム設計 10
4.1 構成とデータの流れ 10
4.2 記号と実装の対応 10
4.3 静的解析手順 11
4.4 動的取得と操作管理 11
4.5 ログアダプタ 11
4.6 開発意図の照合規則 12
4.7 証拠の管理と再現性 12

5 実装と利用方法 13
5.1 実装環境とモジュール 13
5.2 意図JSON 1.1と利用者入力先の許可 13
5.3 意図JSONと1件の指摘をたどる例 13
5.4 標準的な実行例 14
5.5 使用文脈解析とURI対照ランナー 15
5.6 資源制限と入力保護 15
5.7 記録保護と共有版 15

6 評価方法 15

6.1 研究課題 15
6.2 研究デザインとデータの範囲 16
6.3 比較する入力と手法 16
6.4 評価単位と指標 16
6.5 開始状態と操作記録の扱い 16
6.6 妥当性への脅威 17
6.7 差分説明の確認基準 17

7 事前の開発意図に対する仕込み実験の結果 17
7.1 条件の事前保存と原本点検 17
7.2 条件別の主結果 18
7.3 構成要素の事後比較と静的な補助確認 18

8 既存29試行による補助評価と事後処理例 19
8.1 既存入力先への事後ポリシー適用例 19
8.2 局所的な静的引数追跡の結果 19
8.3 URI入力切替による要求先の追随 19
8.4 静的・動的差分を中心とした再解析 20
8.5 対応と差分から得られた説明 20
8.6 補助群のポリシー照合と原本点検 20

9 考察と制約 21
9.1 研究課題への回答 21
9.2 意図を主入力に置く意義 21
9.3 静的解析と動的解析の役割 22
9.4 保留と取得品質の解釈 22
9.5 適用範囲と今後の課題 22

10 結論と今後の課題 22

11 倫理とデータ管理 23

A 素材同定と実装確認 23
A.1 APKと環境の同定 23
A.2 開発用の静的確認 24

B 最終台帳と取得範囲 24
B.1 補助29試行と主評価9試行の構成 24
B.2 主評価9試行の台帳 25
B.3 主評価素材の同定 25
B.4 確認済み範囲と拡張課題 25

C 再現資料とAI支援の記録 26

1　研究背景と問題設定

1.1　開発意図とアプリの振る舞いを確認する必要性

本研究の動機は，自分が作成したアプリが，意図した通信だけを行うか，想定していない権限・SDK・通信先の候補を含むかを開発中に確認したい，という問題である。外部ライブラリやビルド設定を利用する開発では，すべての依存と動作を把握することが難しい。AIによるアプリ作成もその利用場面の一つである。生成方法ごとの危険性を事前に仮定せず，開発者が事前に定めた条件への照合を行う。

自然言語の目的だけから必要通信を推定すると，観測後に意図を補ったり，未指定の条件を禁止と解釈したりするおそれがある。そこで，許可先・通信禁止・権限・SDK・平文・Home後通信・記録された入力先の許可を構造化して入力する。静的候補と実測の差分は，照合結果の根拠と不足を説明するために用いる。

1.2　静的解析と動的観測の相補性

静的解析は，実行しなかった経路を含むコードや宣言を調べられる一方，未使用のURLやSDKの残存コードも候補に含める。動的観測は実際に起きた通信の証拠を得られる一方，操作，待機時間，ネットワーク条件に依存し，観測されなかった経路を網羅できない。両方式は単独では結論できない点が異なるため，証拠を統合する意義がある。

1.3　研究目的と主張の範囲

目的は，開発者が解析前に宣言した意図を主入力とし，APKの静的候補と指定操作下の動的通信を照合して，意図外の候補に根拠付きで気づけるシステムを構築・評価することである。「意図」は構造化した条件として操作的に定義し，自由記述の目的を自動理解した結果とはしない。カテゴリの未指定，明示禁止，許可集合を区別する。

本研究で示す内容は次の2点である。

1. 解析前の構造化意図を主入力とし，固定先と記録された利用者入力先への許可を，帰属・操作・取得条件と合わせて照合する構成を実装する。
2. 自作参照素材の事前意図に対する9試行と保存証拠の再解析により，参照仕様に基づく候補提示，入力先の整合，未観測の保留が規則どおり動作したことを確認する。

差分表と証拠索引は，この照合結果を確認するための根拠表示として位置付ける。

対象は実行・解析の許可がある単一APKとする。送信先・方式・操作区間，権限宣言，登録ルールで一致するSDK候補を確認範囲とする。HTTPS本文の内容，権限の実際の使用，SDKが送信した事実，通信の必要性やアプリ全体の安全性は別の証拠を要する。

1.4　利用者と本研究の構成

対象利用者は，善意でアプリを作成し，依存や生成コードも含めて自己確認したい開発者である。意図的に解析を回避するマルウェア一般への対抗ではなく，開発中の確認支援を扱う。実装は，意図の保存，静的解析・指定操作・取得，意図照合，差分と証拠の表示から構成する。

既存29試行は観測系・帰属・差分説明の成立範囲を示す補助資料として保持する。主評価は事前に意図と仕込み仕様を定めた参照素材で行う。同一AVDで自作3 APKを各3回実行した9試行を主評価とし，原本から意図照合結果を再生成した。既存群との合計は38端末試行だが，意図の時点と評価目的が異なるため別群として報告する。

2　関連研究と本研究の位置付け

2.1　静的・動的解析と実行支援

APKの静的解析，端末上の通信取得，自動操作には既存の実装がある。Androguardは Manifest・DEX等を扱い，本実装の抽出処理の基盤となる[1]。FlowDroidはsourceから sinkへの静的データフロー解析を，LibScoutはライブラリのプロファイルによる識別を扱う [4, 5]。本実装は文字列・宣言・登録特徴の候補抽出と限定した引数追跡を用いる。

DroidBotは実行時の状態遷移とUIを用いるテスト入力生成器であり，ADBによる非計装の操作を扱う[6]。MobSFは静的・動的解析，レポート，API・CLI連携を提供する[8]。本システムは，指定済みの操作と待機を実行する経路を用い，開発意図との比較に必要な記録を保存する。

PCAPdroidとAntMonitorはVPNによる端末上の通信取得に関する先行実装である[3, 12]。本実装はPCAPdroid 2.0.2のUID拡張付きPCAPとCSVを取り込み，インストール記録との整合を確認する。送信元アプリの帰属，取得段階，時刻補正を照合の前提として保存する。自動操作や静的・動的解析の併用そのものは，これらを利用した構成要素として位置付ける。

2.2　プライバシーポリシーと挙動の整合性検査

PoliCheckはデータ型と受信主体のフローをプライバシーポリシーへ照合し，clear, vague，omitted，incorrect，ambiguousの開示状態を定義する[9]。同論文3.1節のentity は主に受信組織であり，本研究が記録する送信元AndroidアプリのUIDとは対象が異なる。 5.2.1節では人手検証の候補180フローのうち不確かな27を分けている。

PurPlianceは，ポリシーと実行通信から得たデータ利用目的を含めて整合性を分析する [7]。6.3節は目的未指定の場合にその条件を検査しないと定め，8.1節と9節は入力生成，ロ グイン，証明書ピンニング等による観測範囲の制約を述べる。本研究は通信から利用目的を 推定せず，解析前に開発者が宣言した構造化条件を入力とする。

PoliGraphは自然言語ポリシーを知識グラフで表し，未指定のデータ・第三者を特別なノ ードで扱う[10]。4.1.2節は辺の生成元となる文の保存を述べる。この未指定はポリシー文の 意味表現であり，本研究の意図カテゴリ未指定，UID不明，取得不足と同一ではない。

表1は確認した範囲での比較である。複数状態への分類，条件未指定の扱い，根拠追跡には 先行例があり，本研究ではそれらを組み合わせた具体的な開発者向け手順を示す。

表 1: 近接研究と本システムの対象。性能の順位付けを示す表ではない。

対象	主な入力・比較対象	不明・未指定の扱い	根拠・確認範囲
PoliCheck	ポリシーとデータ型・受信主体のフロー。	5開示状態と不確かな検証候補の区別。	文の開示とフローの整合。
PurPliance	ポリシーと，目的を含むデータ利用フロー。	目的未指定時の条件非検査，観測制約。	利用目的を含む整合性。
PoliGraph	自然言語ポリシーと，通信との照合に使うグラフ。	未指定ノード，曖昧な記述の表現。	関係の生成元の文を保存。
本システム	開発者の構造化意図，APK，指定操作下の通信。	意図未指定，未観測，帰属・取得不足を分離。	意図・操作・フローから原本の所在とhashへ参照。

2.3 差分観測と本研究の位置付け

Agrigentoは，個人情報の入力源を変える前後の通信を比較し，難読化された漏えいを検出する[11]。本文IV-A節では，時刻・乱数・暗号処理等を計測・記録し，一部を再生・固定することで非決定性を抑えた通信トレースを構成する。説明できない差を潜在的な漏えいとして扱う設計はI節とIV-A節に示され，VII節は反復回数と誤検出，追跡プロトコル，計装範囲の制約を述べる。本研究は登録URIと要求先の対応を補助的に調べ，UIDや取得の根拠不足を判定不能として保存する。私的データ値の変更や非決定性の記録再生，漏えいスコアリングは行わない。したがって，入力切替自体を新規の検出方式とは位置付けない。

本研究の具体的な焦点は，開発者が宣言した固定先・記録入力先の許可条件と，静的候補・指定操作・UID付き観測を結び付け，整合・不一致候補・確認不足を同じ出力から追跡できることにある。この設計を自作素材の事前意図に対して評価し，主張と証拠の範囲を明らかにする。既存研究の自然言語推論やデータフロー解析と同等の機能，性能上の優越は評価対象に含めない。

資料の確認範囲は分けて管理した。PoliCheck，PurPliance，PoliGraph，DroidBot，Agrigentoは論文本文の関連節を，FlowDroid，LibScout，MobSF，AntMonitorは固定した公式実装資料を参照した。比較表は確認した機能を記載し，未調査の機能を「存在しない」とするものではない。

3 理論モデル

3.1 入力と証拠の形式化

構造化した開発意図を I，APKを A，操作シナリオを U，観測条件を C とする。主出力は意図との照合 F であり，静的候補集合 S と動的証拠集合 D の対応説明 X を根拠表示に用いる。研究用の主手順では I を必須とし，カテゴリごとの未指定は許容する。

$$S = f_{\text{static}}(A, R_s), \tag{1}$$

$$D = f_{\text{capture}}(A, U, C), \tag{2}$$

$$X = h(S, D, U, C, R_m), \tag{3}$$

$$F = g(I, S, D, U, R_c), \tag{4}$$

ここで R_s は静的特徴ルール，R_m は通信先対応と説明の規則，R_c は開発意図の照合ルールである。S は実行事実を意味しない。D は条件 C に依存するため，別の操作や待機条件で通信が生じないことを保証しない。

各証拠 e を，出典，場所，時刻，観測段階，帰属，本文可視性からなる組として保存する。

$$e = (\text{id}, \text{source}, \text{locator}, t_0, t_1, o, a, v). \tag{5}$$

静的証拠では時刻は実行時刻を表さず，DEXの文字列番号や命令オフセット，Manifest内の宣言を所在とする。逆コンパイル結果の位置を原ソースの行番号とは扱わない。

3.2 開発意図の明示性

カテゴリ k の意図 I_k は，禁止，許可集合，未指定のいずれかを取る。

$$I_k \in \{\text{deny_all},\ \text{allowlist}(L_k),\ \text{unspecified}\}, \quad L_k \neq \varnothing. \tag{6}$$

通常のallowlistは非空集合を要求し，禁止はdeny_allで表現する。意図JSON 1.1では通信に限って，固定許可先と記録された入力先を併用する`allowlist_or_recorded_inputs`も定める。この形式では固定集合を空にでき，入力先の許可は第5.2節の証拠条件に依存する。未指定を暗黙の禁止へ変換しない。

3.3 部分情報に基づく判定

証拠の不足と条件の未指定を区別する。規則kの前提が成立することを$V_k(e)$，その明示条件に必要な比較が可能なことを$Q_k(I_k, e)$，比較可能な条件を満たすことを$M_k(I_k, e)$とする。通信規則の前提には取得失敗でないことと対象帰属を含み，静的宣言規則に通信UIDの前提を流用しない。判定は次の排他的な分岐で定める。

$$J(I_k, e) = \begin{cases} \text{not_evaluable} & \neg V_k, \\ \text{needs_review} & V_k \wedge I_k = \text{unspecified}, \\ \text{not_evaluable} & V_k \wedge I_k \neq \text{unspecified} \wedge \neg Q_k, \\ \text{mismatch_candidate} & V_k \wedge I_k \neq \text{unspecified} \wedge Q_k \wedge \neg M_k, \\ \text{consistent} & V_k \wedge I_k \neq \text{unspecified} \wedge Q_k \wedge M_k. \end{cases} \tag{7}$$

最後のconsistentは実装値consistent_with_observed_evidenceの略である。Q_kは規則の分岐に依存する。通信禁止では対象接続試行があればホスト名不明でも比較できる。一方，ドメイン許可リストでは必要なホスト根拠がなければ判定不能とする。実装の取得失敗・非対象帰属の除外，未指定の評価，宛先比較という順序に対応する。規則間の指摘を単一の優先度で消去せず，個別に保持する。整合は観測範囲での局所的な判断であり，アプリ全体の安全性ではない。

3.4 独立した観測軸

表2の軸を独立に保存する。単一の危険度スコアへ集約すると，「宣言だけの違い」と「対象アプリの実接続」の差，および未知情報が失われるためである。

表 2: 判定と観測情報の軸

軸	値・意味
verdict	不一致候補，観測範囲で整合，要確認，判定不能
observation	static_only，not_observed，connection_attempt，transport_established，tls_established，http_observed，capture_failed
attribution	target，other，related_candidate，unknown
content visibility	none，metadata_only，plaintext_available
run status	completed，partial，invalid，failed（現実装では主にcompleted/partial/failedを利用）

TCP接続試行，TCP成立，TLS成立，HTTP要求観測は異なる段階である。CONNECTはプロキシに対するトンネル作成要求であり，上流へのTLS成立や本文送信成功を意味しない。PCAPアダプタでは3ウェイハンドシェイクを確認した場合にTCP成立とし，単一セグメントのClientHelloからSNIが読めてもTLS成立へ昇格させない。

3.5 ホスト名照合と未知値

正規化関数 $N(h)$ はIDNのASCII変換，末尾ドットの除去，大小文字の統一，IPの標準表記化を行う。サブドメインの許可フラグを b とすると，照合は次で定義する。

$$M(h, d, b) = [N(h) = N(d)] \vee [b \wedge \neg\text{IP}(d) \wedge N(h)\text{が}.N(d)\text{で終わる}]. \tag{8}$$

ドット境界が必要であり，example.comに対してbadexample.comは一致しない。許可要素はホスト，ポート集合，アプリケーションプロトコル集合を持つ。ポートのみからプロトコルを推定しない。プロトコルが制約されているのに値が不明なら判定不能とする。

同じIPを複数ドメインが共有することやDNSキャッシュがあることから，IPだけで許可ドメインの利用を肯定・否定できない。DNSからの対応付けが曖昧なら，ホスト名をnullとし理由を記録する。現PCAPアダプタはDNS応答からアプリ接続のホストを確定せず，直接見えるHTTP HostやSNIを利用する。

3.6 アプリ帰属

対象APKのpackageを p_A，そのインストールのUIDを u_A とする。ログのUID u_e が一致し，package情報と矛盾しない場合に対象候補とする。package名だけが一致してもUIDが不明ならunknownとする。再インストールでUIDが変わり得るため，u_A は実験ごとに取得する。

同じUIDを共有する構成，OSサービスへの委譲，外部ブラウザ経由の処理には限界がある。またSDKはアプリと同一UIDで動作し得るため，UID一致はSDK名への帰属を意味しない。別UIDの通信を単に無関係とせず，取得元の注記がある場合はrelated_candidateとする。

3.7 操作との時間的対応

ログ時刻 t_d は，測定した差分 Δ を用いてホスト基準に変換する。

$$t_h = t_d + \Delta, \qquad E(e) = \{u_i \mid t_i^{\text{start}} \le t_h \le t_i^{\text{end}},\ u_i\text{が成功}\}. \tag{9}$$

対応する操作IDは時間的な関連を表すのみで，因果関係を示さない。Home後区間は操作上の定義であり，OSの厳密なバックグラウンド実行状態と同一視しない。待機対照と反復を用いて代替説明を検討する必要がある。

3.8 未観測の条件

not_observedは，正常性が確認された観測系で，指定区間内に該当記録がなかった場合の限定的表現である。取得前後の対照不成立，欠落区間，操作失敗がある試行を「通信なし」の正解として集計しない。さらに，対照が成立しても観測ツールやアダプタの対応範囲外の通信は残る。

3.9 時刻の不確実性と実装範囲

補正時刻の候補を$J_t = [t_d + \widehat{\Delta} - \varepsilon, t_d + \widehat{\Delta} + \varepsilon]$とする。現行正規化は，フロー開始時刻のこの幅が操作区間へ収まる場合と，境界へ重なる場合を区分し，対応操作IDと境界不明の状態を保存する。新しい入力先許可では，フローの開始から終了までの範囲に時計幅を加え，操作区間内への包含を再確認する。

時計差は前後測定に整合する定数差という条件を持ち，ドリフト上限や操作時刻そのものの誤差を独立に実証した結果とは区別する。取得品質partialと時刻対応の条件を保存する。

3.10 静的候補と実測の対応・差分モデル

静的URL文字列はホストとポートで集約する。同じ文字列が複数箇所にあっても宛先候補は同じ組とし，元の所在と証拠IDは保持する。既知のXML名前空間等は参照ヒントとして別保存する。動的側は正規化フローであり，静的宛先組と同じ単位ではない。

候補sと対象帰属のフローdの対応関係を，現在の実装では次で定義する。

$$R(s,d) = \text{target}(d) \wedge \text{valid}(d) \wedge (d.\text{transport} = \text{TCP}) \wedge (s.\text{port} = d.\text{port}) \wedge H(s,d). \quad (10)$$

validは取得失敗を表す記録でないこと，Hは候補が明示IPなら宛先IPの一致，ドメインなら記録ホスト名の一致である。ドメインをIPから推測せず，URLパス・スキームの実行成立・命令から送信へのデータフローまでは対応させない。従って，これは通信先候補の対応モデルであり，静的な送信経路の実行証明ではない。

候補側は，対応する対象フローがあれば「対応あり」，有効な取得がないか対応の可能性を残す帰属・ホスト不足があれば「判断不能」，残りを「静的のみ」とする。対応済みでない動的記録は，対象帰属・既知ホスト・静的処理完了を満たす場合に現在の規則で「動的のみ」とし，満たさなければ「判断不能」とする。別UIDは対象差分へ混入させず原本へ残す。TCP以外は対応規則の範囲外であることを説明に明示する。これらの分類は危険性や原因のラベルではない。

表 3: 単独情報と併用で説明できる内容の違い。性能の優劣を表す表ではない。

確認する内容	静的のみ	動的のみ	併用
APK内の候補と所在	確認可能	入力がない	確認可能
取得窓の通信・UID	入力がない	確認可能	確認可能
候補と実測の対応	実測不足	候補不足	条件の範囲で可能
差の原因の確定	一般には不可	一般には不可	補助証拠なしには不可

3.11 差分を説明する情報の分離

各対応表行rに対し，説明を$X_r = (F_r, G_r, H_r, N_r, E_r)$とする。$F_r$は候補・実測・比較処理から直接確認した事実，$G_r$は不足する情報，$H_r$は未確認の原因候補，$N_r$はこの結果から断定しない事項，$E_r$は証拠IDと出典の項目である。原因候補$H_r$を確認事実$F_r$に昇格させない。

`explanation.py`は，検証済み対応表から決定的なテンプレートでこれらを生成する。確認事実には`static.json`，`flows.jsonl`，`run.json`，`correspondence.json`の項目参照を付け，静的・動的事実には証拠IDを併記する。差分の原因を生成AIが自由記述で断定する処理ではない。例えば動的のみ行の「実行時入力の可能性」は未確認欄に残し，RSSの入力URLが記録で確認できたという事例解釈は，保存シナリオによる別の確認として述べる。

出力は`difference-explanation.json`とCSV，既存HTML内の説明欄である。元の対応表，静的・動的記録，開発意図との照合結果は変更しない。説明の項目が埋まることと，原因の正解・利用者の理解を証明することは区別する。

3.12 研究用要求の補助点検

研究用HTTPの原本点検では，試行ごとのtoken，宛先，対象UID，時計補正後の時刻を用いてサーバー受信記録との候補対応を求める。単一パケットに完全なGETヘッダがあり，対応するサーバー側のGET・200・書込み完了と補正時刻差1秒以内で対応する場合に記録する。NATによるポート変換と条件付きの時計差が残るため，接続同一性の確定とは区別する。

既存の公開アプリの補助事例では，同じAPKにA・BのURIをABBA順で入力し，4試行すべてで対象要求先が登録先へ追随することを確認した。主評価では入力先要求と固定先要求のいずれも検索し，サーバーとの候補対応を別に点検する。候補対応は照合結果の検証を補強する資料であり，C02の判定入力そのものへ自動結合する機能ではない。

4　システム設計

4.1　構成とデータの流れ

図1に全体の処理を示す。意図の内容と読み込み時点を最初に保存し，照合結果と差分説明を独立に生成する。

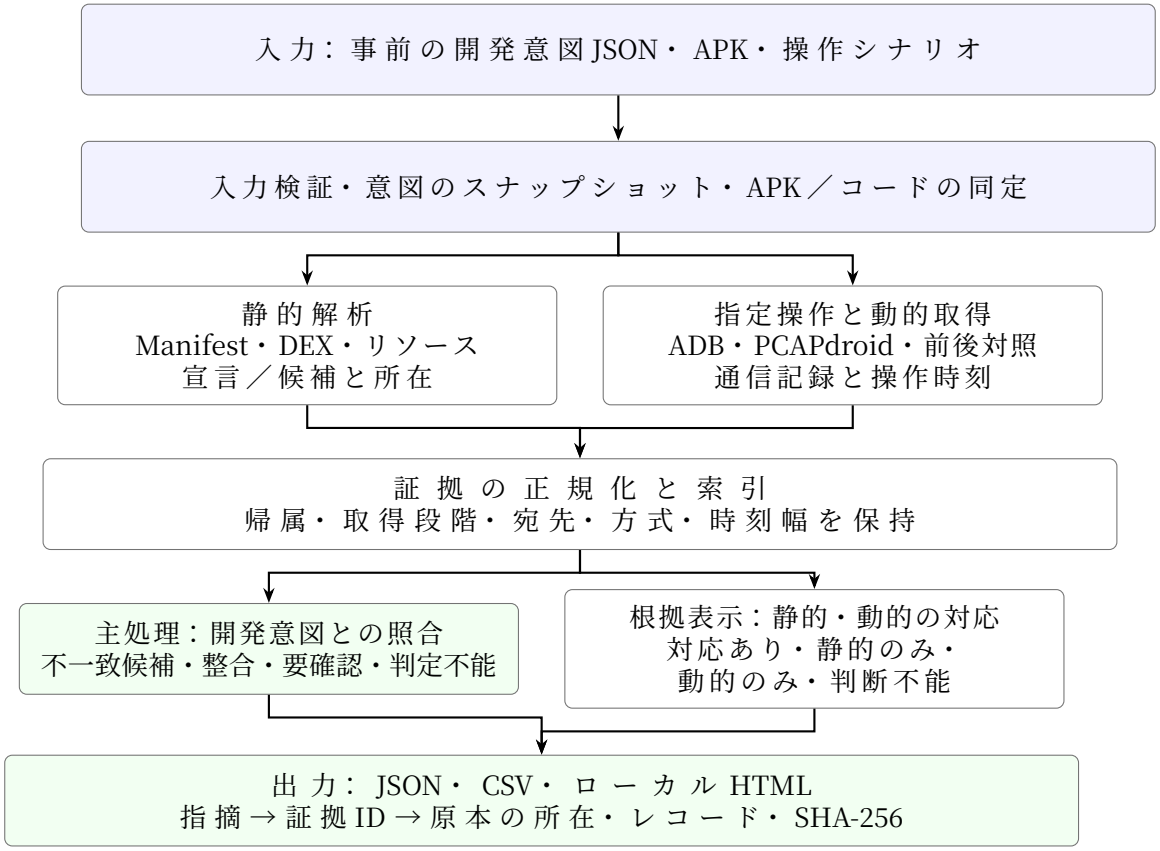


図 1: システム構成。意図は解析前に保存し，照合と差分説明は別の規則で生成する。

入力検証器はスキーマ，APK形式，サイズ，矛盾を検査する。静的解析器は候補の抽出だけを担当し，禁止判定は照合器に分離する。観測アダプタは入力形式ごとの証拠を共通のフロー形式へ変換する。レポートはJSON正本から生成し，独立した判定軸を保存する。

4.2　記号と実装の対応

表 4: 理論モデルと実装モジュールの対応

記号・処理	実装上の対応
A, I, U, C	APK，intent，scenario，run/capture metadata
f_{static}	static.pyとworker。Manifest・DEX等の候補抽出
f_{capture}	automatic.py，補助APK，PCAPdroid，capture.py。過去試行は半自動ランナーとCSVアダプタ
g, J	compare.pyの規則別ポリシー照合
h：対応と差分説明	differential.pyとexplanation.py。対応表，確認事実・不足・未確認の原因候補の構造化
証拠e	原本，evidence/index.json，core.py，report.py

従来のandroid.pyによるEmulator console PCAP経路は，本稿の半自動PCAPdroid実測とは別であり，端末実証済みとみなさない。

4.3 静的解析手順

処理の概要を以下に示す。

1. APKのサイズ，ZIPメンバーの名前，重複，展開量，Manifest・DEXの有無を検査する。
2. 元APKを改変せず保存し，SHA-256を計算する。
3. AndroguardでManifestを復号し，基本情報，権限，コンポーネント，通信設定を取得する。
4. すべてのclasses系DEXを走査し，文字列，クラス特徴，登録済みAPIへのinvoke命令を抽出する。
5. 選択したリソースとARSC文字列を走査し，URL候補の元値，正規化結果，所在を保存する。
6. SDKルールのclass接頭辞とManifest文字列を照合し，単一種類と複数種類の特徴一致を区別する。
7. 処理済みファイル，対象外ファイル，警告，失敗を出力する。

Android 15の固定ソースでは，Network Security Configの指定時にXML設定を選び，未指定時にManifestの平文フラグを参照する。既定のユーザーCA信頼にもtarget SDK条件がある[2]。本実装は設定上の許可と実際に観測した平文要求を別の指摘にする。

現在のSDKルールはFirebase Analytics，Google Mobile Ads，Facebook App Events，Sentry Androidの4種である。接頭辞一致は候補検出であり，バージョン確定，実行，到達可能性，通信主体を証明しない。AndroidX等の一般ライブラリを一括して禁止SDKと扱わない。

4.4 動的取得と操作管理

実装したADB連携は，明示選択されたローカルEmulatorを対象に，元APKのインストール，UID取得，パケット取得，UI操作，取得停止を管理する。現在のanalyzeでは，通常起動は対象packageの前面状態で確認し，tapにはresource-idと期待する到達先IDを指定する。現在の既定経路はアプリデータを保持し，一律のデータ消去や手動チェックポイントの自動承認は行わない。旧runの操作・初期化機能とは区分する。

現行経路はADBとPCAPdroidのCaptureCtrlを組み合わせる。取得前後に補助アプリから研究用HTTPサーバーへ要求し，応答，補助UIDのPCAP記録，取得開始停止を確認する。Mac arm64とAPI35 arm64のAVDで，自動HTTP，公開アプリ起動，RSS操作，URI切替，主評価9試行を実測した。開発用Linux環境ではオフライン再解析を行った。旧Emulator console・ICMP方式は別の試作経路であり，本稿の自動取得の実証範囲は現行CaptureCtrl経路とする。

4.5 ログアダプタ

app-flowは本実装で定義したJSONL契約である。時刻，宛先IP・ポート，TCP/UDP，観測段階，任意のホスト名と根拠，UID，package，送受信量を入力する。加えて，PCAPdroid

2.0.2の固定ソースに基づくCSVアダプタを実装した。原CSVの行を証拠に保存し，列ずれや未確認の版を拒否する。表示状態から接続成立やTLS成立へ昇格させず，Info列からホストの出典を推定しない。Android実測のCSVは列契約と一致した。各試行の時計・取得対照・APK同定の記録範囲をメタデータへ保存し，取得・時計の不確実性をpartialとして保持した。

PCAP/PCAPNGアダプタはクライアントIP側から通信方向を定める。60秒アイドルと新規SYNを区切りとしてフローをまとめるため，その件数は真の接続イベント数と一致する保証がない。TCP再構成やIP断片再構成は未実装であり，SNI・HTTP Hostの抽出範囲は限定される。PCAP単独のアプリ帰属はunknownとする。

同一ファイルの二重取り込みを拒否し，取得元IDを維持する。異なるログの一般的な接続同一性の確定は今後の課題である。研究用HTTPでは第3.12節の限定したサーバー候補対応を別に求める。取得元を横断した単純合計は避け，フローとサーバー要求を別の単位で保存する。

4.6 開発意図の照合規則

表 5: 実装した照合の基本規則

ID	対象	判定の考え方
C01	通信禁止	対象アプリの接続試行を不一致候補とする。接続成立・本文送信とは区別。
C02	通信先許可リスト	帰属，ホスト，ポート，取得できるプロトコルを比較。不明をリスト外とみなさない。
C03	SDK	登録ルールで検出した候補を意図と照合。初期化・送信は断定しない。
C04	権限	Manifest宣言を比較。実際の権限行使やデータ取得を意味しない。
C05	平文	設定上の許可と実際に観測した平文プロトコルを別指摘にする。
C06	Home後通信	成功した操作区間内の対象通信を比較。因果やSDK起因を断定しない。
C07	不足と未指定	条件未指定は要確認，帰属・解析・観測の不足は判定不能として残す。

4.7 証拠の管理と再現性

各runにはAPKのハッシュ，入力条件，版，ホスト情報，操作時刻，取得条件，エラーを保存する。原記録，正規化結果，照合結果を分離し，指摘から証拠ID，原ファイル，レコード位置，ハッシュへ到達できるようにする。レポート生成時に原ファイルのハッシュを再確認する。

ハッシュは保存後の変更検出と入力同定のためのもので，第三者がログを作成した事実や真実性を証明する電子署名ではない。取得系の対照やオフラインUID情報の自己申告には，原記録の保管と実験者による検証が必要である。

依存ライブラリは間接依存を含め版とハッシュを固定する。静的解析の再現性比較では，run ID，時刻，所要時間を除く候補・所在・規則版を比較する。動的結果にはOSスケジューリング，ネットワーク応答，初回同意，キャッシュ等が影響するため完全一致を要求しない。

5　実装と利用方法

5.1　実装環境とモジュール

検証した環境はLinux x86_64，Python 3.12.14である。主要ライブラリはAndroguard 4.1.3，jsonschema 4.25.1，dpkt 1.9.8，defusedxml 0.7.1である。プロジェクトの基礎版は0.1.0であり，主評価の意図JSONは1.1，照合ルール版は`2026-11-06.intent-1.1`である。旧記録は取得時のルール版を保持する。

表 6: Pythonモジュールと責務

モジュール	責務
core / contracts	時刻・ハッシュ・JSON入出力・スキーマ・正規化
static / worker	APK解析と子プロセスの隔離・資源制限
automatic / pcapdroid	実測済みのADB指定操作とPCAPdroid自動制御・UID拡張PCAP
capture	app-flowとPCAPの正規化・帰属・証拠索引
differential / explanation	対応表と構造化した差分説明
compare	開発意図との照合，独立した判定軸
report / share	CSV・HTML，原本を含まない共有用要約
cli / demo	コマンド操作，合成デモ

5.2　意図JSON 1.1と利用者入力先の許可

固定先の許可集合に加え，`allowlist_or_recorded_inputs`を選んだ場合に限り，登録したURI操作の入力先を許可候補へ加える。入力例は`examples/intent-recorded-input-v1.1.json`に示す。固定の許可先集合は空でもよいが，入力を許すURI方式を明示する。通信禁止や未指定の条件に，この例外を自動で加えない。

評価時の候補は固定集合と，宣言が許す登録入力先の和集合として求める。ただし，入力の記録・帰属・時間等の前提が不足する場合は，判定関数の比較可能性Q_kを満たさない。入力先を復元できないことを空の許可集合による禁止へ変換せず，判定不能とする。

入力先に関する整合には，対象UID，完全性を確認したシナリオと操作記録，登録URIとの同一ホスト・ポート，必要な観測プロトコル，時計幅を含めて操作区間内に収まる通信の条件を要求する。根拠を欠く場合は判定不能とし，動的のみの宛先という理由だけでは許可しない。リダイレクト先や任意画面での手入力を暗黙に登録する機能は含まない。

`intent_extensions.py`が形式と入力例外，`compare.py`が規則判定，`intent_overview.py`が主結果表示を担当する。`pipeline.py`は意図を静的解析前に読み込み，保存後の証拠索引へ登録する。保存済み取得への事後適用は別の記録時点として表示する。記録時刻とhashはローカルの追跡資料であり，独立した事前登録証明ではない。

5.3　意図JSONと1件の指摘をたどる例

主評価の意図は，利用者が登録操作で入力したHTTPまたはHTTPSのフィード宛先を許可し，固定の許可先を設けない条件である。INTERNET以外の権限と登録SDK候補は許可しない。以下は実際の意図JSONの通信部分の抜粋であり，完全な入力は公開資料の`examples/intent-recorded-input-v1.1.json`に含めた。

```
"network": {
  "mode": "allowlist_or_recorded_inputs",
  "allowed_destinations": [],
  "recorded_input_protocols": ["http", "https"]
}
```

実測したfixed-001では，登録URIは10.0.2.2:18762を指す一方，対象アプリのHTTP要求は10.0.2.2:18761へ向かった。静的URL文字列候補は0件で，対象通信は対応表で動的のみとなる。照合器は同じホストでもポートが許可条件に含まれないため，C02の不一致候補F00006を生成した。observation=http_observedとattribution=targetを併記する。

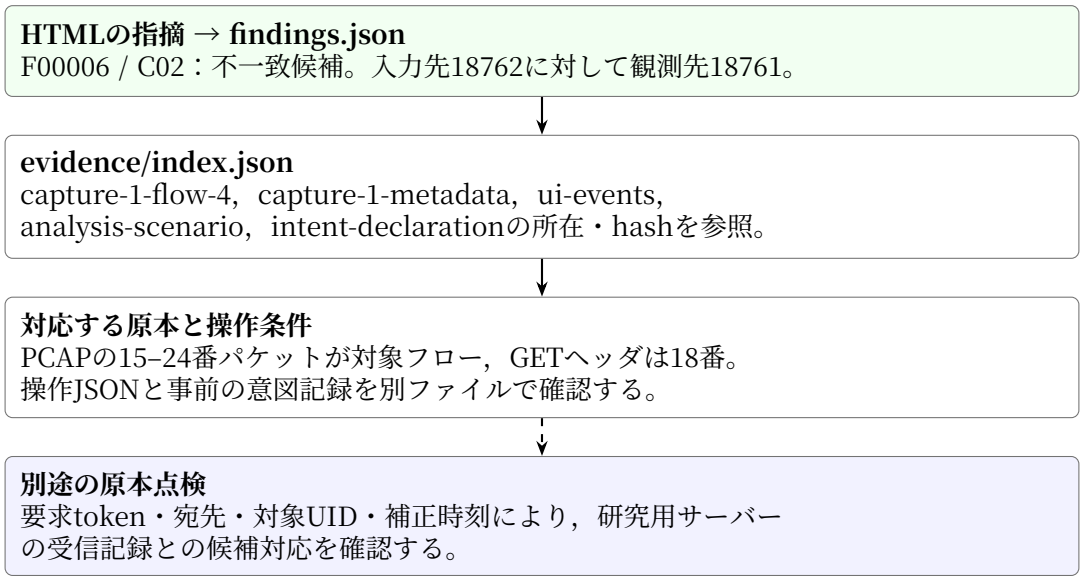


図 2: 実測した固定先要求の証拠追跡。破線のサーバー候補対応は別途の点検であり，C02判定の必須入力ではない。

不一致候補は宣言した宛先条件との違いを示す。開発者は，その接続が実装ミス，依存の追加，意図の記載漏れのどれに当たるかをソース等で調べる。同じ動的のみという差分でも，登録入力先への要求なら今回の条件では整合となる。差分の種類だけで異常を決めず，意図と操作・取得条件を併せて読む。

5.4 標準的な実行例

意図を必須入力とするrun_intent.pyを入口とし，意図，APK，選択済み端末，操作シナリオから，静的解析・指定操作・取得・正規化・照合・根拠表示を連続実行する。引数の概略を以下に示す。

```
python run_intent.py --apk app.apk --intent intent.json \
  --scenario scenario.json --out runs/app-001
```

実際の配置場所，Python環境，Macでの実行コマンドは再現資料のREPRODUCE.mdへまとめた。著者は同資料のコマンドを実行し，Androidの制御・VPN同意を確認した。シナリオ省略時の範囲は起動と待機であり，必要なボタン操作等は事前にシナリオへ指定する。

出力では意図との照合を先頭に表示し，correspondence.jsonの対応分類とdifference-explanation.jsonの確認事実・不足・原因候補を根拠表示に使う。保存済み取得の再解析と新たな端末実行は区別し，初期のCSV試行は半自動取得として台帳へ記録した。

5.5　使用文脈解析とURI対照ランナー

URL・URI生成，OkHttpの文字列URL設定，WebView.loadUrlの4シグネチャを対象に，DEXの基本ブロック内で文字列定義・コピー・限定した結合を追跡する。元のAPK解析結果に加えて，引数候補と命令位置を別出力に保存する。解析の境界を越える値は不明とする。公開APKの対象29箇所では定数URL2，不明27を得た。定数2箇所はプロキシ試験用の`https://www.example.com`とライブラリ初期値の`http://undefined/`である。不明27箇所の`runtime_origins`はすべて空であり，Intent由来と同定した結果ではない。この解析範囲と実行時入力経路の関係は分けて解釈する。

補助ランナーは第3.12節の登録URI操作と要求の確認を実装する。`research_context`が引数追跡，`research_diagnosis`が計画選択と証拠条件の点検，`research_contrast`がURI入力と研究用サーバーを管理する。各試行のAPK・シナリオ・コードhash，前後対照，要求の候補対応を保存する。結果を表8に示す。

5.6　資源制限と入力保護

初期値はAPK上限200 MiB，ZIP内の宣言展開量1 GiB，静的解析10分，動的1試行10分とする。Linuxでは静的ワーカのアドレス空間を3 GiBに制限する。DarwinではRLIMIT_ASの互換性に制約があるため，この制限を適用せず，親の時間上限・APKサイズ・パーサの入力上限を使い，実際の適用状況を記録する。これらは入力保護の設定値である。リソース単体が8 MiBを超える場合は対象外とし，未処理範囲に記録する。

ZIPメンバーの絶対パス，親ディレクトリ参照，危険な区切り，重複を検査し，入力名のまま展開先パスを作らない。JSON文字列をshell命令として実行せず，引数配列を用いる。HTMLはエスケープし，外部資源に依存しない。CSVでは先頭の式記号を無害化する。

子プロセスと資源制限は被害範囲を抑えるが，解析ライブラリの脆弱性を完全に防ぐサンドボックスを実装したものではない。未知APKを扱う研究環境自体も隔離する必要がある。

5.7　記録保護と共有版

研究者用の原本にはトークンや個人情報を含み得るURL・ログが残る。共有版は許可された判定項目だけを抽出し，目的文，ホスト，パス，UID，原本ログ，証拠リンクを省く。これを完全に匿名化した原本や根拠付きレポートとは呼ばず，「証拠を含まない共有用要約」と区別する。

6　評価方法

6.1　研究課題

RQ1 事前に宣言した意図に対して，許可条件外の宛先への要求と権限宣言を，根拠付きの候補として提示できるか。

RQ2 登録した許可入力先への要求と，対象通信が未観測の条件を区別し，整合と判定不能を使い分けられるか。

RQ3 指摘から意図，操作条件，静的・動的の証拠へ戻り，保存原本から照合結果と対応表を再現できるか。

SDK候補抽出は実装機能として記録するが，実SDK検出の精度と被験者の作業時間は今回の評価対象に含めない。

端末試行はすべて著者が手元のMacとAndroid Emulatorで実行した。著者がコマンドを起動し，制御・VPNの同意画面を確認し，各試行の操作状況を記録した。APK・ランナー作成，オフライン再解析，集計，執筆には生成AIの支援を用いた。自動化した取得・照合処理と，著者による端末操作をこの役割分担で実施した。

参照素材・期待値・解析器は同じ開発側で作成した。ソース仕様を期待値の根拠とし，AI支援による原本点検と再現確認を実施した。人の理解度や作業時間を調べる被験者評価は実施していない。

6.2 研究デザインとデータの範囲

主評価は，同一AVDで自作3 APKを各3回実行した9試行である。意図，条件，順序，APKとコードのhash，期待出力を試行前のローカル記録として保存した。表7に結果を示す。参照素材は開発時の確認にも使用しており，独立した未見アプリ標本ではない。

既存29試行は補助群とする。HTTP，UDP，通信なし，HTTP処理不成功，専用信頼設定HTTPS，公開アプリの起動・RSS・URI切替を含み，構成を付録の表13へ集約した。公開アプリはAntennaPod 1本である。意図の時点と取得方法が異なるため，主評価と同一の精度分母に加えない。9と29の合計38は端末試行数であり，アプリ数ではない。全取得品質はpartialで，方式比較と再解析は試行数へ加えない。

6.3 比較する入力と手法

静的のみはAPKの静的結果，動的のみは通信と取得・インストール・操作の共通情報，併用は両者の和集合を用いる。同じAPK・原本・解析規則で，支持できる事実と不足する根拠の差を調べる。サーバー原本やUIは検証の補助資料として区別し，併用だけへ与えた人手情報の効果を方式の優位性とはしない。限定HTTP本文のケース検査も，メタデータ解析本体の機能と区別する。

UID条件の比較では，不明保持・不明行削除・UID条件だけを除去した方式を同じ記録へ適用する。これは構成要素の事後比較であり，実際の外部ツールの挙動や独立した正解への誤検出率ではない。事後の禁止・未指定ポリシーは取得前条件とは区別して表示する。3方式比較済みの制御19試行では動的のみと併用の選定通信の判定・状態が一致し，併用による判定精度改善を主張しない。

6.4 評価単位と指標

端末試行，静的候補，正規化フロー，宛先組，HTTP要求・応答，本文照合を別単位とする。観測記録の存在，帰属・可視性・取得品質，静的動的の対応，参照先の所在・hashと事実への支持を確認する。hash一致だけで説明の意味が正しいとはしない。判定不能率等を集計する場合も，どの選定記録を分母としたかを示す。

独立した真値がないため，一般的な適合率，再現率，UID帰属精度，手作業削減率は本稿の主要結果として算出しない。同一AVD反復からアプリ母集団への有意差を求めない。構成要素の比較による「未支持」は，独立に事実誤りが反証された意味ではない。分母0と人手未注釈は未定義・未評価として残す。

6.5 開始状態と操作記録の扱い

RSS001は実施者が購読・再生等を報告した混合操作の事例，002・003は開始前記録がなく追加操作なしと申告された事例として扱う。006では開始前の購読一覧・UI階層・前景情報と，終了後の追加操作なし申告を保存できた。以前の研究用フィードが残っており，空の初

期状態とはしない。可視画面はデータベース全体ではなく，自己申告は全入力の客観的監視ではない。

この記録により試行条件を追跡できる一方，試行間の差を特定操作の因果効果とはしない。UID保持不具合の訂正や追加操作の申告は原本外の解析版・検証記録で追跡する。取得原本は変更せず，訂正の対象と理由を解析版へ記録する。

6.6 妥当性への脅威

内的妥当性 初回同意，アプリデータ，権限，キャッシュ，時刻ずれ，サーバ応答が差の原因になり得る。反復と待機対照，条件の保存で検討する。操作直後の通信という時間関係だけで因果を断定しない。

構成概念妥当性 URL文字列数は通信数の代理にならない。許可先への通信は安全の代理にならない。SDK候補とSDKによる送信も別の概念である。評価単位を事前に固定する。

外的妥当性 単一API/ABI，少数の自作アプリ，4種のSDKルールから他アプリ全般へ一般化できない。難読化，動的ロード，ネイティブ実装，ログインが必要な機能を限界に残す。

評価者の偏り 期待出力は試行前に保存したソース仕様から定めたが，ルール開発と参照素材の作成は同じ開発側で行った。この依存関係と開発時の素材利用が評価を有利にし得るため，本稿は参照条件での成立確認として報告する。

6.7 差分説明の確認基準

保存済み入力を新しい作業先へコピーし，対応表と構造化説明を生成する。試行ごとに訂正済み対応件数の維持，説明行と対応表行の一致，確認事実のファイル・項目参照，証拠IDの存在・hash，原本非変更を確認する。これらは実装上の受入基準であり，説明が利用者に理解される割合や原因推定精度の基準ではない。未知原因を原因候補へ残すことを仕様とし，自動的に正解原因と採点しない。差分規則の分岐は，合成入力で取得失敗・UID不明・ホスト不足・通信方式制約を個別に検査する。合成入力のテストを新しい端末実験へ数えない。

7 事前の開発意図に対する仕込み実験の結果

7.1 条件の事前保存と原本点検

意図を「記録した利用者入力先へのHTTPまたはHTTPS接続を許可し，その他の宛先を許可しない」と定めた。INTERNET権限だけを許可し，SDK候補は許可しない。期待する出力はソース仕様と照合規則から定めた。同一AVD上の自作3 APKについて，入力先，宣言外固定先，観測窓外の送信予定という条件を各3回実行した。各反復の順序は入力先・固定先・遅延，入力ポートは反復ごとに18762・18763・18762である。要求は試行ごとに異なるtokenを含む。

意図JSON，9シナリオと順序，APK・ソース・コードのhash，期待出力を最初の試行前に保存した。各解析でも静的解析前の意図読込みを記録した。これらはローカル記録であり，独立した事前登録や実行証明ではない。期待値は同じ開発側が作成したソース仕様に由来し，素材は開発時の確認にも使った。著者は追加操作を行わず，終了後にその旨を記録した。記録された9試行の全時間は約5分56秒で，初回準備等を含む一般的な作業時間ではない。

著者が実行した9試行の記録をZIPで保存した。Linuxの別作業先へ安全性とhashを検査して復元し，298ファイルを変更せず保管した。使用したコード版とAPK同定，取得前後の対照，インストール記録とPCAP内UIDの整合，操作区間と時計補正，静的解析の再生成を点検した。PCAPから9試行の正規化フロー，意図照合，対応表を再生成し，保存出力と一致した。各試行の前後2要求，計18対照要求は，補助アプリUID・要求ID・PCAP・対照サーバー記録で照合できた。対象要求6件にはtoken・宛先・UID・条件付き補正時刻によるサーバー候補対応がある。

7.2 条件別の主結果

表7に主要な出力を示す。観測窓は入力後30秒，固定先ポートは18761とした。

表 7: 事前意図に対する規則の動作確認9試行。同一環境内で各条件を3反復した。

条件	動的な証拠	主要な照合出力	期待仕様との対応
許可入力先（3試行）	各1対象HTTP要求。入力したA/B/Aに追随。	C02：観測範囲で整合。入力先・方式・区間の根拠あり。	3/3整合。通信の不一致候補は0/3試行。
宣言外固定先（3試行）	各1対象HTTP要求。入力先によらず固定ポートへ到達。	C02：不一致候補。取得・帰属は比較可能。	3/3で固定先への要求を指摘。
観測窓外の予定（3試行）	対象要求0，既知の別UID通信と前後対照あり。	C07：判定不能。状態は未観測。	3/3で保留。無通信へ変換0/3。

3 APKの静的URL文字列候補は各0件で，権限宣言はINTERNETのみ，登録SDK候補は0件だった。固定先は補助メソッドで組み立てる実装であり，この文字列抽出方式では宛先候補を得なかった。動的証拠では固定先へのHTTP要求を得られたため，その要求を事前意図と比較して指摘できた。補助メソッドで宛先を組み立てるよう作成した自作素材に対し，定めた抽出・照合規則の動作を確認した結果である。

遅延素材は入力から75秒後に要求を開始する仕様である。実際には各試行の入力開始から31.44–32.00秒で対象パッケージの停止応答を記録し，後続試行への遅延要求の混入を抑えた。したがって，遅延送信を検出した結果ではなく，予定された通信に観測窓が届かない場合の保留を確認した結果である。サーバー記録は入力先3件・固定先3件の計6件で，遅延条件のtokenに対応する受信は記録されていない。

対象要求6件と保留3件の根拠参照は，インデックスの所在とhashまで確認できた。全取得品質はpartialである。`delayed-001`は停止統計39に対して保存40パケット，`fixed-003`は38に対して39パケットで，各1パケットの差があった。原因を確定せず，残る全パケットを再解析した。9試行の正規化フローに帰属不明はなかったが，UIDの独立した正確性や全通信の取得を証明するものではない。

7.3 構成要素の事後比較と静的な補助確認

同じ9原本と事前意図へ，静的のみ・動的のみ・併用を事後に適用し，計27出力を生成した。再解析は新しい端末試行へ数えない。静的のみでは通信実測を評価対象外とし，3 APKの宛先候補も0件だった。動的のみと併用の主要通信出力は9試行すべてで一致し，入力先の整合3，固定先の不一致候補3，対象未観測による判定不能3となった。この群だけから，併用が動的のみより高精度だとはいえない。

別の静的補助素材では，位置APIも通信APIも呼ばず，位置権限だけを宣言したAPKを用いた。コンパイル・署名検査と`aapt2 dump permissions`による宣言確認を行い，許可集合にな

いACCESS_FINE_LOCATIONをC04の不一致候補として提示できた。この素材は9端末試行に含めず，権限の実使用や位置情報送信の結果にも数えない。実SDKとAI生成アプリ一般の評価は別課題とする。

8　既存29試行による補助評価と事後処理例

8.1　既存入力先への事後ポリシー適用例

既存のURI切替4試行のコピーへ，後から仮定した入力先許可の意図JSONを適用した。対象要求4件は，登録URI・対象UID・HTTP・時刻区間との照合により，いずれも観測範囲の整合となった。出力には意図の時点をnot_established_or_retrospectiveと記録した。この処理例は入力例外の説明であり，元アプリ開発者の意図，事前固定の正解，検出精度を評価した結果ではない。原本と従来の規則判定は保持した。

8.2　局所的な静的引数追跡の結果

対応APIの引数29箇所のうち，定数として復元できたのは2箇所，不明は27箇所であった。この結果は基本ブロック内追跡の解決範囲を示す。Intent由来のタグを持つ箇所は0である。したがって，不明27箇所をRSS入力経路へ一括対応させる根拠にはせず，登録したURI操作と実測要求を追加の証拠として調べた。

8.3　URI入力切替による要求先の追随

4試行すべてで，対象UIDの要求先ポートは入力ポートと一致し，A・Bの切替に追随した。Aは2試行とも59521番，Bは2試行とも59522番であった。表8に入力と観測の対応を示す。各試行で前後の取得対照が成立し，第3.12節の入力追随基準を満たした。

表 8: URI切替の補助事例。同一APK・同一AVDでの反復確認。

試行	入力	入力ポート	観測ポート	HTTP	GETパケット
1	A	59521	59521	200	43
2	B	59522	59522	200	55
3	B	59522	59522	200	53
4	A	59521	59521	200	39

対象はAntennaPod 3.12.3で，入力順序ABBA，起動待機5秒，URI操作後30秒の計画を用いた。入力先以外の既存アプリデータは保持した。各試行のパスは別のnonceを持つ。対象UID10213の要求と，そのnonceを持つサーバー受信記録の候補対応を確認した。保持したHTTP 200応答には各184 Bの本文があり，使用したサーバー仕様から再構成したRSS本文と一致した。

全試行の静的候補は同じ38宛先組で，対象要求先への対応候補はなく，対象フロー1件が「動的のみ」となった。入力を変えても静的候補は同じである一方，実測した研究用要求先は入力とともに変わった。これにより，この差分を「抽出候補にない通信」と表示する段階から，「登録入力先に追随する要求を確認した」と説明する段階へ補強できた。

記録の整合性と不確実性　静的結果・全フロー・規則判定・対応表・診断を保存原本から再計算し，対象出力が再現した。3試行目には別にUID不明のUDP/443が1フローあり，対象アプリへ補完せず判断不能として保存した。1試行目では停止統計123パケットに対し保存

PCAPが124パケットであり，末尾の対象外UDP1パケットの差を記録した。取得全体の品質partialと未確定の原因を記録した。

観測は入力先と要求の対応を支持する。ポート，nonceパス，RSSの自己参照先がともに変わり，開始状態の復元は実施していないため，単一要因の効果や実行コード箇所の確定は別に扱う。追加操作なしは取得後申告として保存した。条件内の反復確認を，アプリ母集団への精度推定へ広げない。

8.4　静的・動的差分を中心とした再解析

既存25試行を新しい作業先へコピーし，対応表の各行に確認事実，不足情報，未確認の原因候補，断定しない事項と原本参照を付加した。公開起動は訂正済みUID版を使用した。25試行すべてで従来の訂正済み対応件数を維持し，参照原本も変更していない。これは説明形式と出典参照を対象にした実装確認である。

表 9: 主要事例の差分分類。件数は対応表の行数であり，通信回数ではない。

事例	対応あり	静的のみ	動的のみ	判断不能
自動HTTP	1	1	0	0
公開アプリ起動	0	38	0	0
RSS001	0	38	3	0
RSS002	0	38	2	0
RSS003	0	38	2	0
RSS006	0	38	2	0

自動HTTPでは静的2候補のうち1候補に対象通信が対応し，残る1候補は取得範囲で未対応だった。公開起動では候補38組がある一方，対象UIDの通信は未観測だった。RSS006は静的38組と対応しない実測2フローを得たが，2フローは1宛先の記録であり，静的候補組数とフロー数を別に表示した。研究用URLが実行時に与えられた事実は保存シナリオで別途確認する。一般行の原因は未確認欄として保持する。

8.5　対応と差分から得られた説明

自動HTTPでは，APK内の明示IP・ポートと対象UIDの通信が対応した。公開アプリの通常起動では，静的候補がある一方で対象要求は未観測だった。RSS条件では実行時に研究用URLを入力し，静的候補に含まれない実測を得た。RSS006の別途点検では，GET応答本文679 Bと音声HEAD本文0 Bを確認し，2フロー・3要求・1宛先を別の単位で記録した。

表10に差分説明の各段階を示す。確認事実と，不足・未確認の原因候補を分けることで，どの資料を次に調べるかを示せる。各段階の出力は，原因の確定や利用者の理解度を測る結果とは区別する。

8.6　補助群のポリシー照合と原本点検

制御19試行では，静的のみ・動的のみ・併用の計57出力を作成し，動的のみと併用の選定通信の判定・状態が一致した。帰属不明4単位に対して，不明保持・不明行削除・UID条件除去を事後に適用した場合は出力が変化した。これらは同じ記録の構成要素比較であり，独立した真値に対する検出精度の評価とは区別する。

既存25試行の保存入力から規則判定を再生成し，訂正済みの出力との整合を確認した。公開起動の旧版UID欠落を訂正し，RSS001の購読・再生操作，RSS006の既存購読，URI切替

表 10: RSS006の差分説明と根拠。

説明の段階	内容
静的側の事実	URLを集約した38宛先組に，入力した研究用宛先と対応する候補がない。
動的側の事実	対象UIDの2フローが同じ研究用IP・ポートに向かう。取得品質はpartial。
対応表	現在の対応規則で動的のみ2行。候補組数とフロー数は別単位で表示。
原因候補	実行時入力・組み立て・設定・解析範囲外等を未確認欄へ保存。
別途の事例点検	シナリオに研究用RSS URLがあり，保持パケットにGETとHEADを確認。
残る不足	要求を生成したコード箇所，本文のアプリ内消費，全操作の網羅。

の統計差と帰属不明を台帳へ反映した。著者による端末操作と生成AI支援による再解析の範囲は方法章に記した。対象は単一AVDと公開アプリ1本であり，再解析を新しい端末試行に数えない。

9 考察と制約

9.1 研究課題への回答

表11に，研究課題と主評価の対応を示す。各回答は事前意図と指定操作の範囲に限定する。

表 11: 研究課題，結果，根拠範囲の対応

課題	結果からの回答	根拠と範囲
RQ1	固定先への要求を3/3試行で不一致候補として提示した。別の静的素材で許可外の位置権限宣言も提示した。	固定先3要求の対象UID・宛先・HTTP。権限はManifest宣言の別確認。
RQ2	許可入力先3試行は整合とし，通信の不一致指摘は0/3だった。対象未観測3試行を判定不能として保持した。	登録操作・方式・時刻条件と照合。一般的な誤検出率や未観測の完全性とは区別する。
RQ3	9試行の照合結果と静的・動的の対応表を原本から再現し，指摘の証拠参照を確認した。	意図・操作・フロー・原本索引の所在とhash。利用者理解度や作業時間は未評価。

9.2 意図を主入力に置く意義

許可入力先と固定先の両条件は，静的URL候補0件に対して対象HTTP要求が見えるという点で共通していた。それでも，登録入力先への要求は整合，条件外の固定先への要求は不一致候補となった。差分の種類だけでは異常を決められず，解析前の意図が判断の意味を与えることを，この条件で示した。

入力先の許可は，観測後に見つかった全宛先を許可集合へ追加する処理ではない。宣言した例外に対し，登録操作・対象UID・宛先・方式・時刻区間の条件が満たされた要求だけを比較する。開発者は原本へ戻り，実装の誤り，依存の追加，意図の記載漏れなどを調べることができる。

9.3　静的解析と動的解析の役割

自作の固定先素材では，文字列抽出で宛先候補を得られず，動的に要求を記録した。これは補助メソッドで宛先を組み立てるよう作成した素材での結果であり，既知の仕様に対する動作確認である。別の権限素材は，実行しなくてもManifestの宣言を静的に指摘できた。両方式は異なる種類の事実を与える。

同じ9原本の事後比較では，動的のみと併用の主要な通信判定は一致した。現在確認できる併用の価値は，通信判定の精度改善ではなく，宣言・候補・実測の対応と不足を同時に読める点にある。公開アプリの補助事例も，静的候補がある通常起動で対象要求が未観測となる場合と，候補にない実行時入力先へ要求する場合を示した。

9.4　保留と取得品質の解釈

遅延条件は75秒後に要求を開始する仕様だが，観測は入力後30秒で終わり，その後に対象を停止した。未観測3試行の結果は，その条件で結論を保留できたという確認である。遅延送信の検出や，今後も通信しないことの実証ではない。

取得前後の対照が成立した9試行にも，停止統計と保存PCAPの1パケット差が2試行で併存した。追加分はいずれも既知の別UIDのパケットだった。対象要求の局所的な確認と取得全体の完全性を別に扱い，全保存パケットと品質partialを保持した。主評価9試行には帰属不明の通信はなく，帰属不明を保持する処理の根拠は，補助群の短時間UDP4単位に対する事後比較に限られる。主評価の対象未観測による保留と，この帰属不明の保持を区別する。

9.5　適用範囲と今後の課題

本稿は，単一AVDと同じ開発側の素材による設計・事例評価である。ソース仕様に基づく期待値と解析前のローカル保存は，評価の条件を追跡する根拠となる一方，独立した未見アプリの正解や第三者による実行証明にはならない。主張をこの範囲に限定する。

プライバシー確認への利用では，意図外の宛先や権限候補へ気づくことを支援する。同じ許可先へ送った本文の適切性，権限の実使用，SDKの初期化・送信，アプリ全体の安全性には別の証拠が必要である。AI支援開発も自己確認の利用場面として位置付け，AI生成アプリの危険性・安全性を評価済みとはしない。

観測窓の延長，実SDK，別素材・環境，第三者による理解度や作業時間の評価は，評価範囲を広げる拡張課題である。本稿は既存の主評価9試行と補助29試行を用いて結論をまとめ，これらの拡張を結論成立の前提とはしない。

10　結論と今後の課題

本研究は，開発者が事前に宣言した構造化意図を，APKの静的候補と指定操作下の通信へ照合する確認支援システムを実装した。差分説明は照合の根拠表示として位置付け，記録された入力先の許可には帰属・操作・宛先・方式・時間の条件を設けた。意図の未指定，宣言との不一致候補，取得・帰属の不足を別に保存し，確認対象と判断不足を併記するよう設計した。

同一AVD・自作3 APKの主評価9試行では，事前意図で許可した入力先への要求を3/3試行で整合，宣言外の固定先への要求を3/3試行で不一致候補とした。観測窓外に送信予定がある3試行は判定不能として保持し，通信なしや安全へ変換しなかった。対象要求6件のPCAP・対象UID・登録操作・サーバー候補対応と，前後18対照要求を原本で確認し，9試行の正規化と照合出力を再現した。静的な位置権限宣言の補助素材も意図外の宣言として提示できた。既存29試行と事後処理例は取得系・差分説明の補助結果として区別した。

以上の結果は，設計した規則が，自作素材の意図した条件で期待どおり動作することを確認したものである。自作の固定先素材では文字列抽出で候補を得られず，動的に要求を記録した。素材は当該の組立て方を持つよう作成しており，静的解析一般の検出能力や併用による精度向上を示す比較とは区別する。

主評価9試行には帰属不明の通信はなかった。帰属不明を対象へ補完せず保持する処理は，補助群の短時間UDP4単位に対する事後比較で確認した範囲である。観測窓の延長，実SDK，別素材・環境への適用，独立した第三者確認は拡張課題に位置付け，今回の動作確認と区別する。

11　倫理とデータ管理

解析・実行の許可がある研究用APKとAVDを用い，位置情報等はダミーデータとする。原本ログ・画面には個人情報や認証情報が含まれ得るため，研究者用保管と共有用集計を分ける。公開成果物には原本の全文を追加せず，必要な集計・所在・hashを保存した。これを完全な匿名化や第三者による真実性の保証とはしない。外部SDK・公開素材・生成コードを追加する場合は利用条件を確認し，実装，テスト・解析補助，文章構成・草稿・推敲に生成AI支援を使用した。使用範囲と検証責任を付録に記録し，所属機関・投稿先の規定に合わせて開示する。

A　素材同定と実装確認

A.1　APKと環境の同定

公開アプリはF-Droid配布のAntennaPod 3.12.3，packageは`de.danoeh.antennapod`である。使用したAPKのSHA-256を以下に示す。

```
6e79f28f69cef1a8b2e4f5f88c9c3cf3c3d7c51356f01394ac23b0dc5d56a00b
```

AndroidはAPI35，ABIはarm64-v8aで，AVD名は`Pixel_8_Edited_API_35`，実行時serialは`emulator-5554`である。build fingerprintは次の値である。

```
google/sdk_gphone64_arm64/emu64a:15/AP31.240517.022/11948202:userdebug/dev-keys
```

実行ホストはmacOS 27.2 arm64，Python 3.11.9，ADB 35.0.1，収集器はPCAPdroid 2.0.2である。開発用LinuxではAndroguard 4.1.3，dpkt 1.9.8を用いて原本を再解析した。API35は自作素材のビルド条件と実行AVDをそろえる固定条件であり，Android全版の代表として選んだものではない。

初期の静的処理確認にはAndroguard公式リポジトリの`tests/data/APK/hello-world.apk`も用いた。取得元コミットは`581f7a3251545a97f66ee92b674dd810ee380a00`，サイズは1,722,314 bytes，SHA-256は次の値である。

```
f427a0ebe0bca97b9acf6cd2a2a01c37a7d3762841810fc54a7191ec637330b2
```

静的URL候補202件，登録API参照41件，登録SDK候補0件を得た。これらは所在別の抽出件数であり，実通信や実SDKの精度値とは区別する。このAPKの端末実行は本稿の38端末試行に含まない。

A.2　開発用の静的確認

通信なし，HTTP，HTTPS，UDP，位置取得のみ，位置取得とHTTPS，遅延，Activity非表示後，クラッシュ，複数DEXの10素材を作成し，生成仕様と解析結果を103項目で照合した。パッケージ名はaapt2とも照合した。開発過程で作成した素材・期待値を用いる回帰確認として扱う。

採用したソフトウェア検査は総数333件が成功した。これは開発用の自動検査であり，端末試行や一般精度の標本に数えない。模擬Sentryクラスは接頭辞ルールの確認用であり，実SDK正例から除外する。引数文脈の6ケースでは実DEX上の定数・限定結合・分岐・実行時入力等を確認した。自動テストとこれらの開発用確認は，端末試行や未見アプリの精度標本と別に管理する。

表 12: 自作素材の静的確認。時間は各1回の例。

Case	Checks	URLs	API refs	Time (s)
offline	10/10	2	0	0.92
http	10/10	3	12	0.72
https	10/10	2	12	0.47
udp	10/10	2	6	0.52
location_only	10/10	2	2	0.52
location_https	10/10	2	16	0.37
delayed	10/10	3	12	0.53
after_home	10/10	3	12	0.52
crash	10/10	2	0	0.37
static_multidex	13/13	3	1	0.37

B　最終台帳と取得範囲

B.1　補助29試行と主評価9試行の構成

表13に既存の補助群をまとめる。対象記録と不明候補は試行内で併存できるため，別列の指標とする。取得原本と解析版の経緯は研究台帳に保存し，主評価9試行は表7に分ける。 全試

表 13: 既存の補助29試行の構成。対象・不明は該当記録を含む試行数。

条件・取得経路	試行数	対象あり	不明候補あり
HTTP・CSV	4	4	0
通信なし条件・CSV	1	0	0
短時間UDP・CSV	4	0	4
保持UDP・CSV	4	4	0
HTTP処理不成功・CSV	3	3	0
専用信頼HTTPS・CSV	3	3	0
自動HTTP・PCAP	1	1	0
公開アプリ起動	1	0	0
RSS・購読再生等の追加操作	1	1	0
RSSプレビュー	3	3	0
URI切替（追加群）	4	4	1
合計	29	23	5

行はAPI35・arm64の単一AVDで取得し，品質をpartialとして保存した。既存25試行の相互排他的な内訳は対象あり19，不明候補4，いずれもなし2である。追加4試行には全て対象記

録があり，うち1試行には別に不明フローがある。上表の対象23と不明5は重複を含む列であり，両列を足して無通信試行を推定しない。

新主評価は許可入力先3，宣言外固定先3，観測窓外予定3の計9試行で，対象記録を含む試行は6，帰属不明を含む試行は0だった。既存群と合わせて38端末試行，対象記録あり29，帰属不明候補あり5となる。対象・不明の列は引き続き重複を許し，38試行を単一の精度標本や同一の事前計画として扱わない。静的だけの位置権限参照素材と計27出力の構成要素再解析は，端末試行数に加えない。

B.2　主評価9試行の台帳

表 14: 主評価の各試行。未観測は対象要求の不在という観測状態であり，無通信の真値ではない。

試行	入力ポート	観測ポート	主要出力	統計差
input-001	18762	18762	整合	0
fixed-001	18762	18761	不一致候補	0
delayed-001	18762	—	判定不能	1
input-002	18763	18763	整合	0
fixed-002	18763	18761	不一致候補	0
delayed-002	18763	—	判定不能	0
input-003	18762	18762	整合	0
fixed-003	18762	18761	不一致候補	1
delayed-003	18762	—	判定不能	0

統計差は保存パケット数から停止時の報告数を引いた値である。全9試行で前後対照が成立し，取得品質はpartialとした。6件の対象HTTP要求は収集器の対象UIDとインストール記録に整合し，別UIDの通信は対象判定へ含めなかった。

B.3　主評価素材の同定

下記のSHA-256で自作参照APKを同定した。入力先・固定先・遅延の3素材を端末実行し，位置権限だけの素材は静的確認に用いた。 **input**　org.example.apkaudit.compare.input

ff52bf88a4772fe96d65846cb544732a3f368f41a9814eaea7ced67e7298f22f

fixed　org.example.apkaudit.compare.fixed

30eece5f249998c814110ea0abf8b07f83d3ae57e0a2384cb220f6216f7ab153

delayed　org.example.apkaudit.compare.delayed

ea47bcc2b948b5a5e63fb5da5206fcb6e423b8367ef50b1a61da86aafa941d18

permissiononly　org.example.apkaudit.compare.permissiononly

9ab2e497eefe174748715a60a5e655b927f7d8a0269b4ac4998819b523e41c98

B.4　確認済み範囲と拡張課題

表 15: 取得経路と機能の最終確認範囲

項目	確認済み	拡張時の確認事項
ADB・自動取得	MacのAPI35 AVDで自動HTTP，公開起動，RSS，URI切替，意図照合9試行。CaptureCtrlと前後HTTP対照。	別AVD・実機・収集器版。
HTTP	対象UID要求，制御サーバー記録，URI4試行の200・保持本文。	分割ヘッダ・一般TCP再構成。
HTTPS	専用信頼設定のAndroid制御APKで3試行。CSVとアプリ・参照サーバーの記録。	一般アプリのTLS・ピンニング。
HTTP処理不成功	Androidで3試行。対象接続試行とアプリのSocketTimeoutException。	失敗原因別・TLS失敗の分類。
UDP	短時間と保持条件の実記録。UID不明と既知UIDを保存。	同一APKで保持時間だけを変えた比較。
静的文脈	対応4 APIの基本ブロック内追跡。公開APK29箇所と開発用DEX。	ブロック・メソッドをまたぐ追跡。
操作・初期状態	シナリオ・時刻・終了後申告。RSS006は開始前画面。	状態復元・入力の独立監視。
旧 Emulator console	試作実装を保存。現行取得結果と区分。	この経路自体の端末評価。
Home後・遅延等	75秒予定・30秒窓の保留3試行。Home後等は開発用確認。	長い窓での送信観測・Home後条件。

C　再現資料とAI支援の記録

原APK，PCAP，CSV，UI・サーバー記録とインデックスを研究者用に保管し，公開資料には集計と再生成ソースを収録する。実行記録のインデックスとhashを確認してから，別作業先で正規化・照合・説明を再生成する。公開起動のUID訂正，RSS001の追加操作，RSS006の既存購読，URI4試行の統計差を現行台帳に反映した。入力の同定・訂正・解析版の履歴は研究台帳に記録する。

論文のTeX，補助29試行CSV，主評価9試行と構成要素再解析の集計，URI4試行の集計，主張と証拠範囲のJSONを公開する。原本再解析には研究者用の入力と依存環境を必要とする。外部へ出す原本は，利用許諾と機微情報を個別に確認して選ぶ。

ChatGPT/Codexによる実装，テスト設計・不具合修正，解析補助，文章構成・草稿作成，翻訳・推敲の支援と，研究者が提示したClaudeによる草稿レビューを使用した。AIの出力は実装ソース・保存記録との照合により点検した。AI点検を第三者による独立した正解付けと区別する。所属機関と投稿先の規定を確認し，提出時に実際の製品・利用日・利用範囲と著者の確認責任を確定して記載する。AIは著者とせず，著者情報・共著者・謝辞は研究者と指導教員が確定する。

参考文献

[1] Androguard project, official README, version 4.1.3. https://github.com/androguard/androguard/blob/v4.1.3/README.md. 2026年11月6日確認。

[2] Android Open Source Project, ManifestConfigSource.java and NetworkSecurityConfig.java, tag android-15.0.0_r1, core/java/android/security/net/config/. https://github.com/aosp-mirror/platform_frameworks_base/tree/android-15.0.0_r1/core/java/android/security/net/config. 2026年11月6日に上記2ファイルの実装と説明を確認。

[3] Emanuele Faranda et al., PCAPdroid official source, version 2.0.2, commit 66f7b3514540c20add8655a74dfee93d00a9563b. https://github.com/emanuele-f/PCAPdroid/tree/66f7b3514540c20add8655a74dfee93d00a9563b. 2026年11月6日に固定版READMEを再確認。取得・UID関連実装は2026年10月29日に確認。

[4] FlowDroid project, "FlowDroid Data Flow Analysis Tool," official README, commit 9bf10349ec6fdceebbcfda2d261a1f23b9e2e439. https://github.com/secure-software-engineering/FlowDroid/blob/9bf10349ec6fdceebbcfda2d261a1f23b9e2e439/README.MD. 2026年11月6日に公式実装資料を確認。査読論文本文の引用ではない。

[5] LibScout project, official README, commit 8c0bd2c147e818841fc695eecb1246e38458435f. https://github.com/reddr/LibScout/blob/8c0bd2c147e818841fc695eecb1246e38458435f/README.md. 2026年11月6日に公式実装資料を確認。

[6] Y. Li, Z. Yang, Y. Guo, X. Chen, "DroidBot: A Lightweight UI-Guided Test Input Generator for Android," ICSE Companion, 2017. 著者公開本文を確認。https://github.com/ylimit/ylimit.github.io/blob/6a5166cfccb87933125a10fc2e6a93b8da2a790a/static/files/DroidBot_ICSE2017.pdf. 2026年11月3日確認。

[7] D. Bui, Y. Yao, K. G. Shin, J.-M. Choi, J. Shin, "Consistency Analysis of Data-Usage Purposes in Mobile Apps," ACM CCS, pp. 2824–2843, 2021. https://doi.org/10.1145/3460120.3484536. 著者公開本文の導入，5.1–5.2節，6.3節，8.1節，9節を確認。公開PDF: https://github.com/ducalpha/ducalpha.github.io/blob/23dcda0e9efa5bcffa0306cd4ad7dfc307a2af8c/files/ccs21-duc.pdf. 2026年11月3日確認。

[8] MobSF project, official README, commit 9c2c08645370f5e404abf9a5c68012daf6dfc433. https://github.com/MobSF/Mobile-Security-Framework-MobSF/blob/9c2c08645370f5e404abf9a5c68012daf6dfc433/README.md. 2026年11月6日確認。公式ツール資料であり，性能比較実験は未実施。

[9] B. Andow, S. Y. Mahmud, J. Whitaker, W. Enck, B. Reaves, K. Singh, S. Egelman, "Actions Speak Louder than Words: Entity-Sensitive Privacy Policy and Data Flow Analysis with PoliCheck," 29th USENIX Security Symposium, pp.985–1002, 2020. 提供PDFの関連節を2026年11月5日に確認。掲載ページ：https://www.usenix.org/conference/usenixsecurity20/presentation/andow.

[10] H. Cui, R. Trimananda, A. Markopoulou, S. Jordan, "PoliGraph: Automated Privacy Policy Analysis using Knowledge Graphs," 32nd USENIX Security Symposium, pp.1037–1054, 2023. 提供PDFの関連節を2026年11月5日に確認。掲載ページ：https://www.usenix.org/conference/usenixsecurity23/presentation/cui.

[11] A. Continella, Y. Fratantonio, M. Lindorfer, A. Puccetti, A. Zand, C. Kruegel, G. Vigna, "Obfuscation-Resilient Privacy Leak Detection for Mobile Apps Through Differential Analysis," NDSS, 2017. 著者公開本文のI・III・IV-A・VII・VIII節を2026年11月6日に確認。https://github.com/conand/conand.me/blob/914dfac45303595a2d8e1c687af881818a8806f6/publications/continella-agrigento-2017.pdf.

[12] AntMonitor project, official README, commit 01f09829cbe6388cbe43582f57defc805b912362. https://github.com/UCI-Networking-Group/AntMonitor. 2026年11月6日確認。端末上VPN取得・検査とライブラリの説明を確認。

論文本文と公式実装資料の確認範囲を区別し，オンライン資料には確認日と採用版・取得元を記した。主評価のAPK・コード同定とデータ構成は付録に示す。